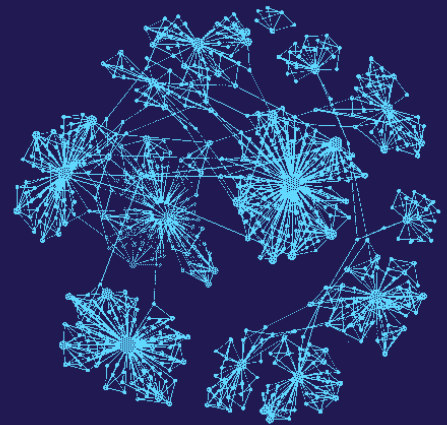

BSI Grundschutz++

Anforderungen zum Risikomanagement

S. Dierkes



Inhaltsverzeichnis

Einleitung BSI Grundsatz++	2
Disclaimer	2
Lizenz	2
BSI Anforderungen zum Risikomanagement	3
Praktik: RISK Risikomanagement	4
Control: RISK.1.1 - Methodik für das Risikomanagement	5
Control: RISK.1.2 - Einhaltung der BSI-Kriterien	6
Control: RISK.1.3 - Risikoeigentümer	7
Control: RISK.1.4 - Risikoappetit	8
Control: RISK.1.5 - Freigabe des Risikomanagements	9
Control: RISK.1.6 - Kritikalitätskriterien für Geschäftsprozesse	10
Control: RISK.1.7 - Kriterien für die Risikobeurteilung	11
Control: RISK.1.8 - Kriterien für die Risikoakzeptanz	12
Control: RISK.1.9 - Bestätigung des Restrisikos	13
Control: RISK.1.10 - Freigabe der Umsetzungsplanung	14

Einleitung BSI Grundschutz++

Dieses Dokument wurde automatisch generiert aus den OSCAL Dateien des BSI für den neuen Grundschutz++ und bildet den zum Zeitpunkt der Generierung verfügbaren Datenbestand ab.

Disclaimer

Dieses Dokument dient ausschließlich der Information, Dokumentation und internen Unterstützung.

Es wird keine Gewähr für die Richtigkeit, Vollständigkeit, Aktualität oder Eignung für einen bestimmten Zweck übernommen. Jegliche Nutzung erfolgt auf eigene Verantwortung. Vor operativen, fachlichen, rechtlichen oder regulatorischen Entscheidungen sind die Inhalte eigenständig zu prüfen und bei Bedarf fachlich zu validieren. Automatisch erzeugte Verknüpfungen, Klassifizierungen, Zuordnungen oder Auswertungen können vereinfachend sein und bedürfen gegebenenfalls einer manuellen Nachprüfung.

Lizenz

Dieses Dokument basiert auf Inhalten des **Bundesamts für Sicherheit in der Informationstechnik (BSI)** aus dem Projekt **Stand der Technik Bibliothek (Grundschutz++)**.

Originalquelle:

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek>

Verwendete Bestandteile:

- Anwendungskatalog (OSCAL)
- Namespace-Definitionen
- Quellkataloge

Die Originalinhalte stehen unter der Lizenz **Creative Commons Attribution-ShareAlike 4.0 International (CC BY-SA 4.0)**:

<https://creativecommons.org/licenses/by-sa/4.0/>

Dieses Dokument stellt eine bearbeitete bzw. transformierte Fassung dar und wird gemäß den Bedingungen der Lizenz ebenfalls unter **CC BY-SA 4.0** bereitgestellt.

BSI Anforderungen zum Risikomanagement

Norm

Beschreibung Quellkataloge

Version 0.9

zuletzt geändert 2026-04-02T05:14:21.040558Z

Keywords

URL

<https://github.com/BSI-Bund/Stand-der-Technik-Bibliothek/raw/refs/heads/main/Quellkataloge/Risikomanagement/BSI-Anforderungen-zum-Risikomanagement-catalog.json>

Rollen

ID Titel / Beschreibung

publisher Publisher

Referenzen

Relation Label / Link

Praktik: RISK Risikomanagement

Kürzel	RISK
auch bekannt als	Risk Management
Schwerpunkt	Methodik

Definition

Risikomanagement ist ein systematischer, wiederkehrender Zyklus, mit dem Ziel, Risiken für die Vertraulichkeit, Integrität und Verfügbarkeit von Informationen zu identifizieren, zu bewerten, zu steuern und kontinuierlich zu überwachen. Es dient dazu, Risiken auf ein akzeptables Maß zu reduzieren.

Untergeordnete Gruppen:

- RISK.1 Risiko

Control: RISK.1.1 - Methodik für das Risikomanagement

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: b6f7870d-6113-4039-974b-df571540c2f3

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS einheitliche Methoden nach {{ insert: param, risk.1.1-prm1 }} verankern.

Guidance

Diese Methoden müssen den Kontext der Institution und die Anforderungen interessierter Parteien sowie die hieraus abgeleiteten Ziele berücksichtigen. Die Methoden können frei gewählt werden.

Control: RISK.1.2 - Einhaltung der BSI-Kriterien

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 3ac69ca1-773a-4605-83e8-fc3a63388a2d

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS die Einhaltung des BSI-Kriterienkatalogs bei der Methodenauswahl anweisen.

Guidance

Im Anhang des BSI-Dokuments zur Risikobetrachtung befinden sich einschlägige Kriterien.

Control: RISK.1.3 - Risikoeigentümer

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 1a225ac3-6072-44ba-bfd6-b30e52477dd4

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS die Rolle des Risikoeigentümers mit den notwendigen Aufgaben und Befugnissen verankern.

Guidance

Der Risikoeigentümer trägt die Verantwortung für die Behandlung von Risiken. Er verfügt über die Befugnis, Entscheidungen über eine geeignete Risikobehandlung zu treffen.

Control: RISK.1.4 - Risikoappetit

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 162c1099-8bc3-4bc7-851a-636291308bb1

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS eine grundlegende Einstufung des Risikoappetits durch die Institutionsleitung festlegen.

Guidance

Diese Einstufung berücksichtigt die Geschäftsziele und dient als Orientierungsrahmen für die Priorisierung zur Behandlung der ermittelten Risiken.

Control: RISK.1.5 - Freigabe des Risikomanagements

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 75cea6b4-d254-462e-9d20-09085e81f1dc

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS Verfahren, Rollendefinitionen und Kriterien durch die Institutionsleitung autorisieren.

Guidance

Diese Dokumentation der Autorisierung dient der Nachvollziehbarkeit und Verbindlichkeit.

Control: RISK.1.6 - Kritikalitätskriterien für Geschäftsprozesse

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: b092d4cb-5c4e-49bc-a1ce-f40d22d3b5ec

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS einheitliche Kriterien für die Kritikalität von Geschäftsprozessen bzw. -aktivitäten und Informationen verankern.

Guidance

Kritikalitätskriterien dienen der Bewertung potenzieller Schäden bei einer Beeinträchtigung der Schutzziele Vertraulichkeit, Integrität oder Verfügbarkeit. Eine Orientierung an den Geschäfts- und Schutzzielen der Institution unterstützt eine konsistente Einschätzung. Dabei bietet es sich an, klar definierte und nachvollziehbare Stufen (z. B. niedrig, mittel, hoch) für unterschiedliche Schadensszenarien wie zum Beispiel finanzielle Verluste, Reputationsschäden oder rechtliche Konsequenzen festzulegen.

Control: RISK.1.7 - Kriterien für die Risikobeurteilung

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: f6e125dc-4554-4ad9-82d7-5b0bca97521a

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS einheitliche Kriterien für die Bewertung von Risiken verankern.

Guidance

Risikokriterien für die Bewertung von Risiken dienen der Quantifizierung oder Qualifizierung der Risiken, um eine Priorisierung zu ermöglichen. Hierbei werden beispielsweise die Eintrittswahrscheinlichkeit, die Schadensauswirkung sowie potentielle Konsequenzen systematisch an Hand von Kriterien bewertet.

Control: RISK.1.8 - Kriterien für die Risikoakzeptanz

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: a687403b-f8ca-4f15-8978-ceb295106f62

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS einheitliche Kriterien für die Risikoakzeptanz verankern.

Guidance

Risikokriterien für die Akzeptanz legen fest, bis zu welchem Risikoniveau eine Institution bereit ist, ein identifiziertes Risiko ohne weitere Maßnahmen hinzunehmen. Diese Kriterien bilden den Rahmen für konsistente und nachvollziehbare Entscheidungen im Risikomanagement. Die Einstufung erfolgt in der Regel anhand der Schadenshöhe und Eintrittswahrscheinlichkeit, wodurch eine Zuordnung zu definierten Risikoklassen ermöglicht wird.

Control: RISK.1.9 - Bestätigung des Restrisikos

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 3e515ecc-0f01-4a43-90c8-c165ae3d28ee

Aufwand: 2

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement SOLLTE die Kenntnisnahme des Restrisikos durch die Risikoeigentümer verankern.

Guidance

Durch nicht umgesetzte Anforderungen entsteht ein Restrisiko, von dem der Risikoeigentümer Kenntnis haben SOLL. Der Risikoeigentümer SOLL dieses Risiko bis zur Umsetzung bewusst tragen. Grundlage hierfür ist der Umsetzungsplan.

Control: RISK.1.10 - Freigabe der Umsetzungsplanung

Info

Control der Klasse "BSI-Anforderungen-zum-Risikomanagement"

Gruppe: RISK.1 Risiko

UUID: 6162c7df-8813-47d4-bbad-4f182c810292

Aufwand: 0

Sicherheitsstufe: normal-SdT

Statement

Risikomanagement MUSS die Umsetzungsplanung durch die Risikoeigentümer autorisieren.

Guidance

Auf der Grundlage des Umsetzungsplans ist eine systematische und transparente Umsetzung der Anforderung bzw. Sicherheitsmaßnahmen möglich. Der Umsetzungsplan enthält z. B. die Anforderungsbeschreibung, das Zielobjekt bzw. den Anwendungsbereich, die verantwortliche Stelle, Start und Zieldatum (Fristen), Prioritäten, Status der Umsetzung, ergänzende Aktivitäten (z. B. Schulungen), Risiken inkl. Begründung (Was bleibt offen? Was wurde nicht umgesetzt und warum?), Ressourcenplanung, Abhängigkeiten zu anderen Anforderungen, Datum der Freigabe und Unterschrift des Risikoeigentümers. Der Umsetzungsplan dient als Grundlage für die Fortschrittskontrolle, die Berichterstattung und Audits.